Threat evolution Q1 2016

GROUP IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Key findings for Q1 2016 3

Predictions 5

Threats to Financial Sector 6

- Mobile Trojans 6
- Banking Trojans and Threats 12
- Attacks on POS terminals and ATM 20

Threats for the Governments 21

- Hacktivism 21
- APT - Advanced Persistent Threat 25

Data Leakage 26

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape. This report covers the first quarter of 2016.

Key findings for Q1 2016

Mobile threats

- An update for GM Bot (GM Bot 2) was released while source codes of its previous version were published in open resources. Also, its author named GanjaMan created a new software named VBV Grabber;
- The well-known "404" criminal group modified its malware for Android (previously they had used malware named Faketoken.c). Currently it is identified as Tiny.z and is known to attack both Russian and foreign banks using a botnet named MarsElite Android BotNet. Incidents of fraud involving this malware have already been detected. Its targets include such banks as Sberbank, Raiffeisen Bank, Russian Standard Bank, VTB 24, Alfa-Bank, PrivatBank, QIWI, Commonwealth Bank, NAB Bank, St. George Bank. At the time of this research (February 2016) the botnet had infected 11,660 devices;
- The ApiMaps group was detected using a Trojan identified as FakeInst.hl;
- A new Trojan containing web injects appeared. It was dubbed Xbot;
- A criminal group using Agent.sx malware designed for the Android operating system was detected.

Banking Threats

- 14 months after the previous campaign, the Proxy criminal group which had earlier attacked Russian, American, Australian and British banks, renewed its attacks focusing on Russian financial institutions. At the moment, they are known to have threatened clients of 3 Russian banks.
- Security specialists detected a new banking Trojan named RTM with special functionality designed to target Russian online banking systems. One of its specific features is the capability of collecting information on new control servers from encrypted messages of a LiveJournal blog;
- To conduct targeted attacks on banks criminals used the Buhtrap backdoor, which means that it was applied not only by the gang of the same name but by others (for example, the Lurk group has been detected to have already used it), because its source codes were published in open resources. Group-IB specialists consider this threat to have extremely high level;
- We can observe activity of the following banking Trojans:
    - for personal computers in Russia: Toplel, RTM, Proxy.Adder, Lurk, Buhtrap, Corkow.
    - for mobile devices in Russia: Marcher, GM-bot, Cron, Tiny.z, Opfake, Fakeinst.fb, Agent.sx, Agent.BID, FakeInst.hl, Honli, Asucub.
    - for personal computers in Europe and the USA: Dridex, Ranbyus, Tinba, Corebot, Gootkit, Vawtrak, ISFB, Qadars, Zeus.
    - for mobile devices in Europe and the USA: Marcher, GM-bot, Tiny.z, Svpeng, Xbot, Asucub.
- It is worth noting that in early January members of the criminal group that used the malware Tyupkin to steal money from European ATM machines were arrested;
- In January a Turkish hacker Zorrokin conducted a series of DDoS attacks on Russian banks.

POS malware

During the reporting period we detected two new modifications of the FighterPOS Trojan, one of them was named “Floki” and had the function of self-distribution over a network infecting the maximum number of POS terminals.

Also, a new version of the CenterPOS Trojan was detected in the USA.

Treats to ATM machines

Hackers used “GreenDispenser” and “Suceful” malware to attack ATM machines in Russia and the Ukraine.

Data leakage

Group-IB specialists detected services selling customers' confidential data related to 3 Russian banks.

Also, data leaks occurred in such companies as Neiman Marcus, Wendy’s, Uber, American Express, and Nexus Mods.

Advanced persistent threats

APT campaigns active in Q1 2016:

- Buhtrap
- Black Energy
- Lurk
- Corkow

Hacktivism

In Q1 2016, the most active hacktivist campaigns were OpAfrica, OpKenya, OpISIS, OpTrump, OpTurkey, OpVenezuela, OpNiUnaMas, OpBEAST, OpWhales, and OpKillingBay. In total, we detected more than 1700 hacktivist attacks on various resources.

Predictions

Based on the threats detected, we can forecast the following future incidents in Russia and the Ukraine:

1) New targeted attacks on financial institutions in Russia and the Ukraine will be conducted by Buhtrap and Lurk hacker groups;
2) The fraudulent activity with Android Trojans used will continue at the same level.
   Groups masking their malware as banking apps will remain the biggest threat.
3) Due to the current political situation, hacktivist attacks targeting Russia are increasing and criminal goals are believed to shift from the terrorizing effect to real financial damage as it was in the case of DDoS attacks on banks.
4) We expect new incidents of attacks on ATM machines using GreenDispenser and Suceful banking Trojans.

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, and Australia:

1) The amount of attacks on bank customers using the Gootkit malware is expected to increase. We observe that criminal groups are gradually refusing to use the Tinba Trojan in favor of the Gootkit malware.
2) Buhtrap source code leakage to the web will lead to creating various modifications of this malware like it was in the Zeus malware case. These modifications may trigger targeted attacks on banks outside Russia;
3) Updated Dridex versions will continue successfully attacking European and American banks' clients and remain one of the most dangerous threats.
4) Modified mobile Trojans based on the GMbot source code leaked to the dark web (aka Mazar and SlemBunk, Bankosy, Acecard and Slempo) will provoke a gradual increase in the amount of fraud incidents.
5) We expect new infections of ATM machines using GreenDispenser and Suceful banking Trojans.

Threats to Financial Sector

❖ Mobile Trojans

Malware name	Regions attacked	Detection	Notification
GM Bot update (GM Bot 2)	All countries except the CIS region	October 2014	CP-1375

An entirely updated version of the GM Bot Trojan targeting Android-based devices was released. Its author named Ganjaman spent the past six months creating this malware. That's why previous GM bot versions were no longer "officially" supported. At the moment, the GM Bot project is believed to have been sold to another forum user named GM_Project. The essential functional difference of the new GM bot version is related to exploits added in order to obtain "root" rights on the victim's device. This enables the Trojan to take control over the device and prevent itself from being removed by antivirus systems or by the user himself. Its exploits are effective for Android versions up to and including 4.3. According to its developer, this enables the malicious program to cover approximately 30-40% of users. The malware contains 3 exploits designed for the following vulnerabilities:

- CVE-2014-3153 (aka towelroot)
- CVE-2013-6282
- Framaroot

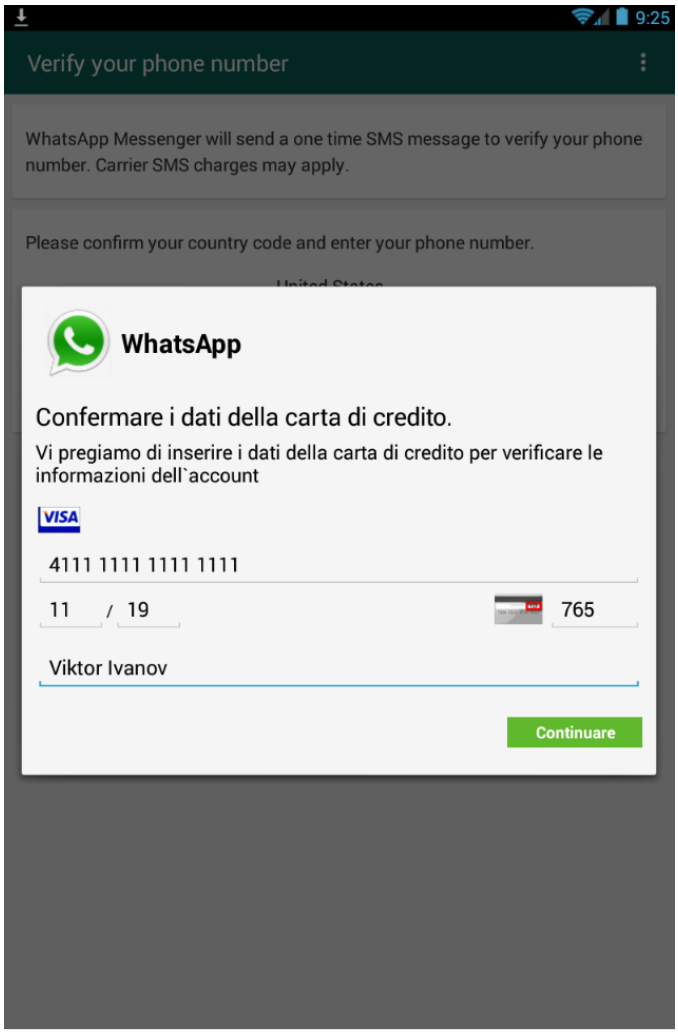
Another important difference as compared to the previous version is ability to intercept SMS messages on Android versions which are higher than 4.4. SMS interception is a two-step procedure:

- An SMS message is transferred to the control panel.
- An SMS message is removed from the user's device.

This function enables criminals to intercept SMS messages remaining unnoticed to the victim. This can be used to conduct fraudulent transactions, in case SMS confirmation is required.

This malware continues supporting the function of injects (fake pages imitating banking apps) to collect authentication information to enter online banking systems. Its author says he has 10 readily accessible injects in his arsenal at the moment. However, in the nearest future over 70 injects of the previous Trojan version are planned to be rewritten.

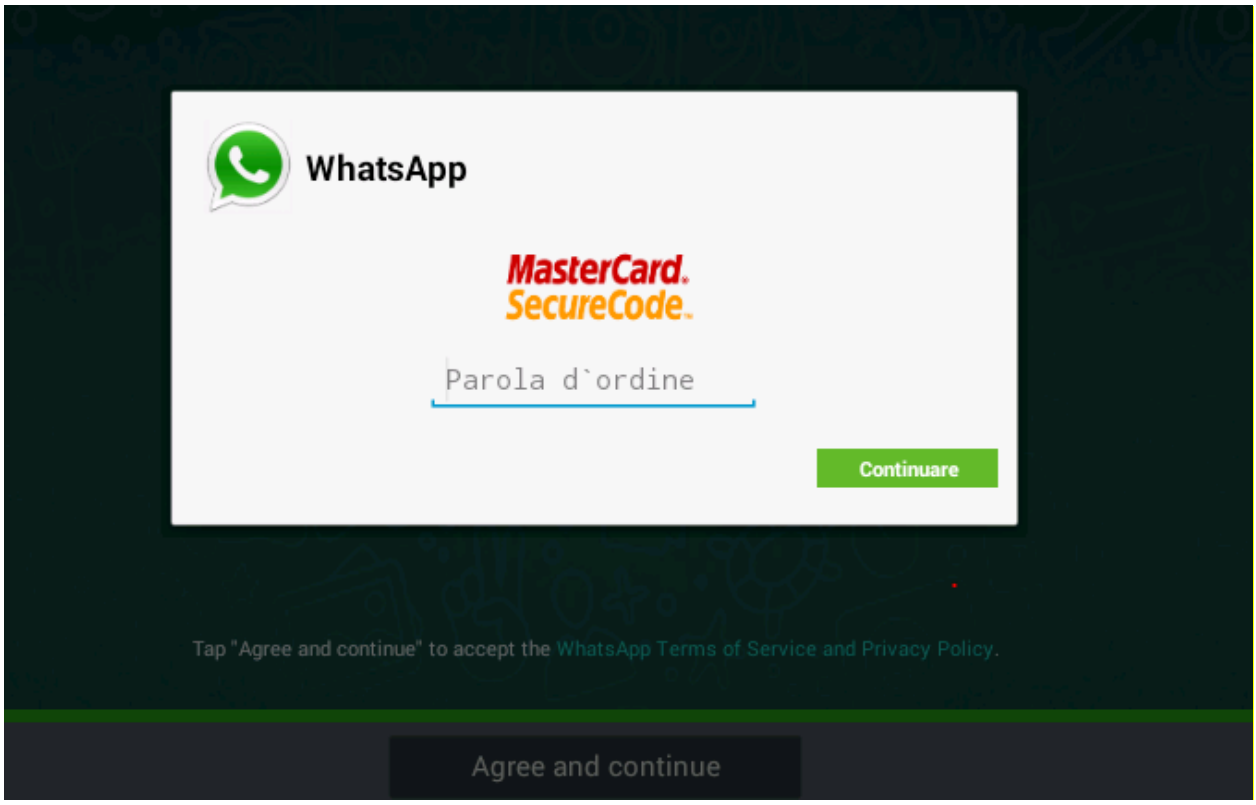
The developer also says that he has modified the system of collecting bank card data. Now the inject designed for the official Whatsapp application is used for these goals. This system was also used by the developer in his another product – Android VBV Grabber.



Also, it's worth noting that in early January source codes of the GM bot's first version were leaked online.

Malware name	Regions attacked	Detection	Notifications
Android VBV Grabber	All countries except the CIS region	February 2016	CP-1373 CP-1373-2

A hacker named Ganjaman developed a new version of GM Bot and a brand new malware VBV Grabber for the Android operating system. This new malware is a mobile Trojan aimed at grabbing bank card data and secure codes (VBV, Securecode). This data is collected using a phishing dialogue box displayed on the top of the official Whatsapp application's interface. This Trojan can intercept SMS messages containing secure codes. Thus, unlike GM Bot, this program doesn't contain specific web injects designed for certain banking applications, but also this malware is much cheaper.



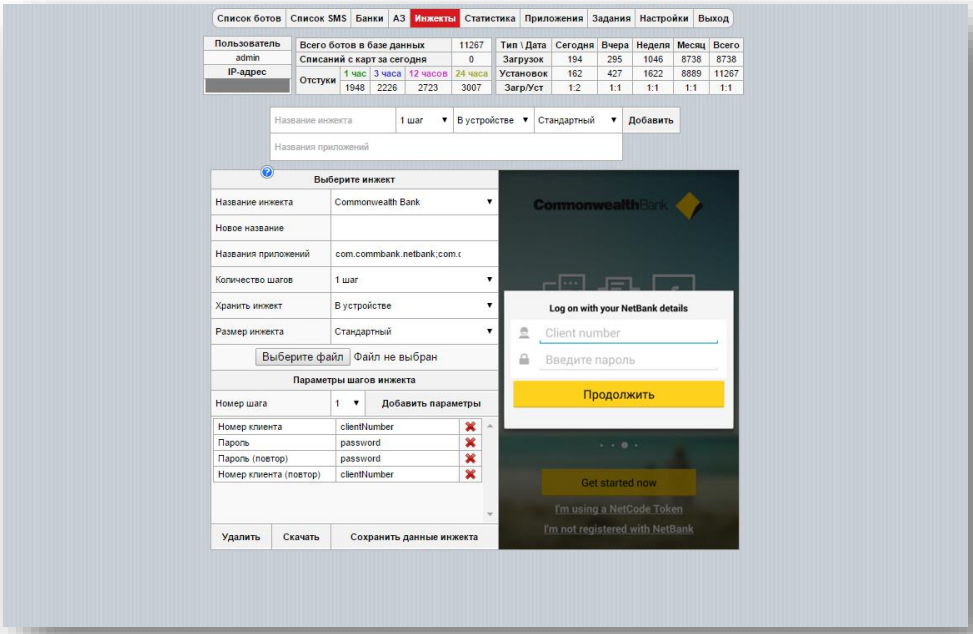
Screenshot – Request for a Secure Code

Malware name	Regions attacked	Detection	Notification
Tiny.z	All	January 2016	CP-1376

The 404 criminal group modified their malware for Android (the Faketoken.c Trojan) to commit fraud. This new Trojan named Tiny.z using the MarsElite Android BotNet was already detected in some fraudulent incidents. It currently targets both Russian and foreign banks, including Sberbank, Raiffeisen Bank, Russian Standard Bank, VTB 24, Alfa-Bank, PrivatBank, QIWI, Commonwealth Bank, NAB Bank, St. George Bank. At the time of this research (February 2016) the botnet had infected 11,660 devices.

The main Tyni.z functions are:

- Obtaining online banking credentials using phishing applications;
- Grabbing bank card data using a phishing Google Play application;
- Getting account balance information by intercepting SMS messages;
- Collecting information on the victim's device (including phone number, IMEI, Android's version, access rights status, victim's region, etc.).

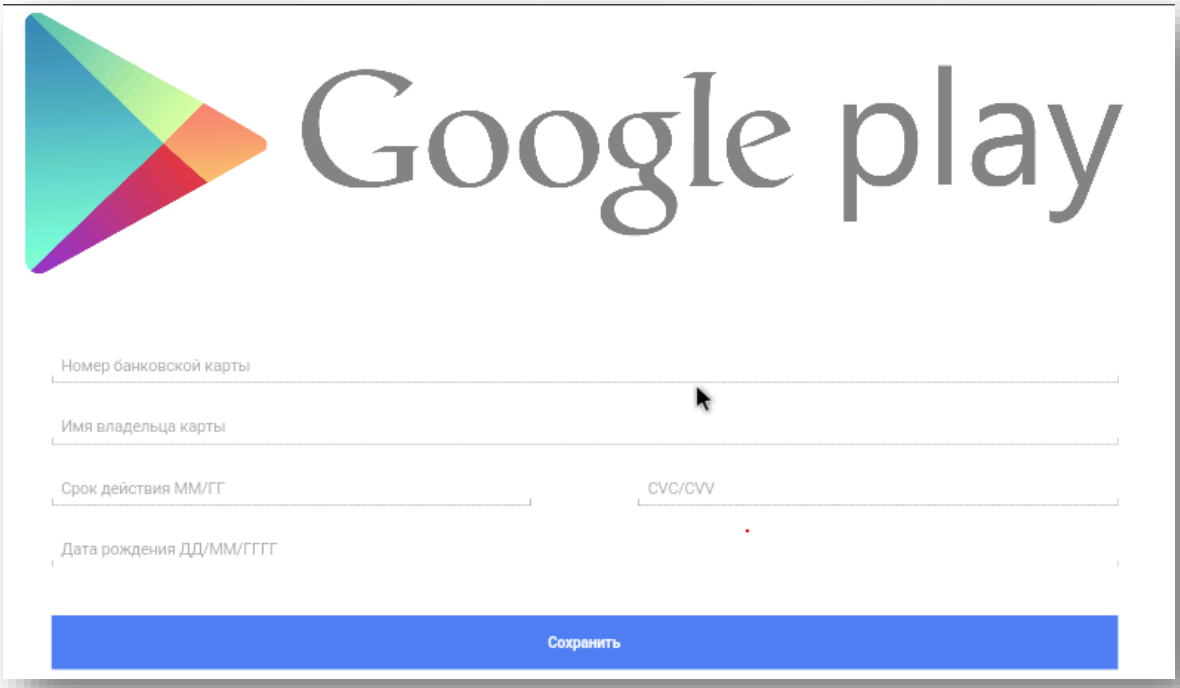


Screenshot – A botnet control panel, a tab with injects for banks

Malware name	Regions attacked	Detection	Notification
Trojan-SMS.AndroidOS.FakeInst.hl	All	February 2016	CG-1145 -3

The ApiMaps criminal group has been active since 2013. Earlier they used the Univert malicious program designed for Android. At the moment, a new version of their Trojan has been detected as Trojan-SMS.AndroidOS.FakeInst.hl. Its key function is collecting bank card data for further fraudulent actions. At the moment two variants of the malware have been detected:

1. A Trojan masked as a Google Play update is able to collect any bank's card data.
2. A Trojan masked as a Sberbank online application targets Sberbank customers requesting their card data.



Screenshot – A Trojan requesting for bank card data

Malware name	Regions attacked	Detection	Notification
Xbot	All	February 2016	CP-1377

Group-IB specialists detected a new Android Trojan detected as “Xbot”.

Injects designed for the following applications were identified at the control server:

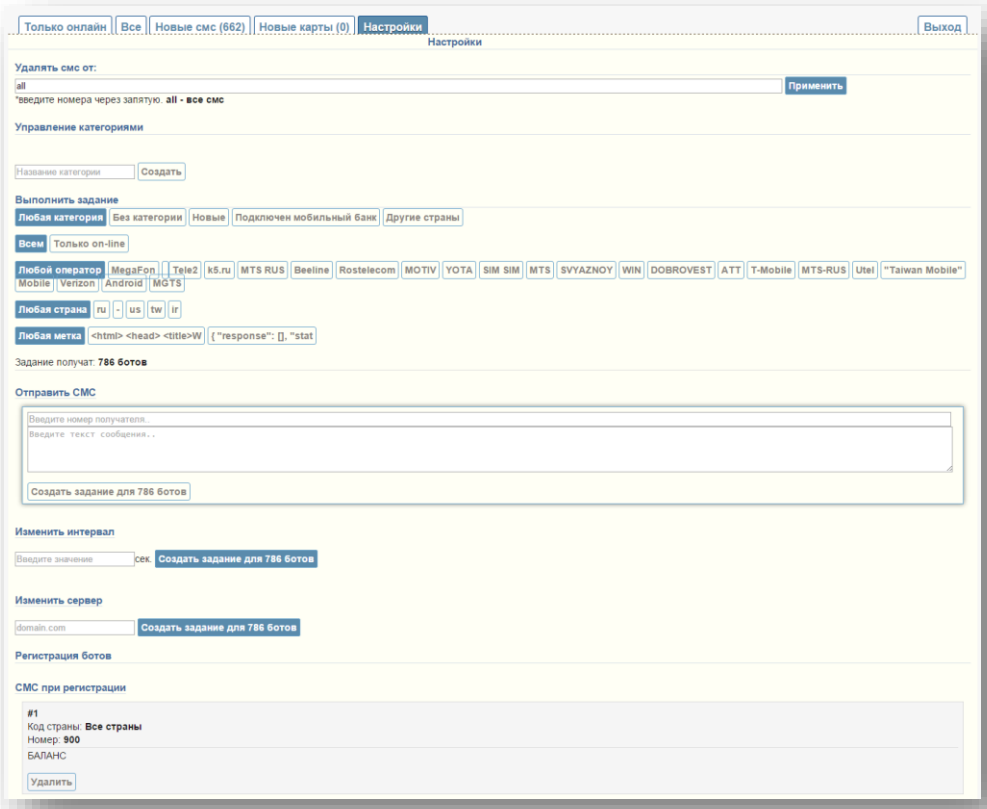
- Google Play for collecting bank card data
- Paypal
- George Bank
- Suncorp bank
- Westpac bank
- Bank SA
- Commonwealth Bank
- NAB bank
- Also, this program targets Sberbank customers, as it is detected to have sent SMS to this bank’s short number

Malware name	Regions attacked	Detection	Notification
Agent.sx	Russia	2015	CP-1383

For the first time the AndroidOS.Agent.sx Trojan was detected in early 2015. The Trojan sends and intercepts SMS messages, after installation it starts sending SMS messages to the Sberbank's short number — 900. In February 2016 Group-IB specialists detected Trojan's distribution points and control panels of the malware. Total number of bots in Agent.sx botnet is 16 thousand.

The control panel has the following buttons:

- Balance inquiry
- Personal account password
- MTS card list (*"Mobile TeleSystems is the largest mobile operator in Russia and CIS")
- Balance inquiry for QIWI
- Balance inquiry for Sberbank
- Information inquiry for Sberbank
- Balance inquiry for PrivatBank
- Balance inquiry for Kukuruza (*"Kukuruza" (Corn) is a multi-functional card with MasterCard payment application used in the "Euroset" loyalty program)
- Balance inquiry for OTP Bank
- Balance inquiry for Alfa Bank
- Tinkoff Bank's card list



Screenshot – the Agent.sx control panel

❖ Banking Trojans and Threats

Threat name	Detection	Notifications
Lurk	2011	CP-1045-3 CP-1045-4 CP-1045-5 CP-1045-6

Group-IB specialists detected a new modification of the banking Trojan Lurk with the following characteristics:

- It looks for a process name uarm.exe. This process name corresponds to the Russian name of the AWS CBC (Automated Working Station of the Central Bank Client) application;
- Lurk is distributed using the AmmyAdmin website, like other Trojans applied by Corkow and Buhtrap gangs to conduct targeted attacks on banks;
- The built-in Mimikatz module used by each criminal group to conduct targeted attacks on banks was added to Lurk;
- Lurk scans both for tabs of Internet banking pages and open pages containing mentions of the Group-IB's Bot-Trek system.
  Like the Corkow malware, Lurk collects data from the Quik trading software developed by ARQA Technologies.
  The full list of detected triggers is available in Notification CP-1045-3.

All these facts evidenced that Lurk could potentially be used to conduct targeted attacks on banks and brokerage systems, like in the Corkow case when malware had been used for the attack at Energobank's currency trading platform.

Later these expectations were confirmed: on March 12, 2016 Lurk together with Mimikatz (a tool designed to gather Windows credentials) and Netscan (a network port scanner tool) was detected in a Ukrainian bank system. The attacks resulted in compromised internal banking infrastructure.

Also, on March 15, 2015 another Lurk attack against a bank was conducted. Criminals used a dropper based on the Buhtrap leaked source code, which was published in February 2016. Also hackers applied LiteManager, a remote control tool, which enabled criminals to install the Lurk malware.

On March 29,2016 we detected an attempt of mass infection attack targeting users of the bankir.ru resource by the Lurk malware using the Angler exploit pack.

Threat name	Detection	Notification
The Proxy criminal group	2012	CP-1362 CG-1385

The Proxy criminal group has been active since 2012. They originally attacked various financial institutions in Russia and the Ukraine: Sberbank, QIWI, VTB24, Promsvyazbank, Alfa Bank, Bank Avangard, Privatbank, Tinkoff Bank.

To conduct attacks this group uses the ProxyAdder/ProxyChanger malware. After its installation and launching on the victim's device the malware modified system settings to redirect users to phishing sites when opening a legitimate website by connecting a victim to malicious proxy servers. Thus,

all user requests to banking webpages were intercepted by criminals. To modify system settings criminals used Proxy Auto-Config (PAC) files, which automatically changed browser settings in order to redirect requests to the proxy server. To intercept HTTPS traffic, the criminals created self-signed certificates for each financial institution and imported them into the malicious proxy server.

In 2015 the gang started attacking financial institutions all over the world. We detected attacks on banks of Australia, Great Britain, Israel (including Bank Leumi, Prepaid Financial Services Limited, St.George Bank, Australia and New Zealand Banking Group, National Australia Bank Limited, Bankwest, and Commonwealth Bank of Australia).

In the beginning of 2016 the gang renewed their attacks against Russian banks. In January 2016 we detected malicious emails threatening Sberbank.

In February 2016 Group-IB analysts detected changes in the PAC file indicating that VTB 24 and Russian Standard Bank became the gang's new targets.

In March 2016 researchers detected a new malware sample which was known to threaten Tinkoff bank and Avangard Bank in addition to its previous targets. Now the malware sends data obtained from infected devices to the control panel which enables the criminal group to determine the number of infected devices and their regions.

Threat name	**Detection**	**Notification**
Banking Trojan RTM	December 2015	CP-1359

In late 2015 Group-IB specialists detected a new Trojan. A detailed analysis revealed that the program was a modular banking Trojan written in Delphi. This Trojan was dubbed RTM.

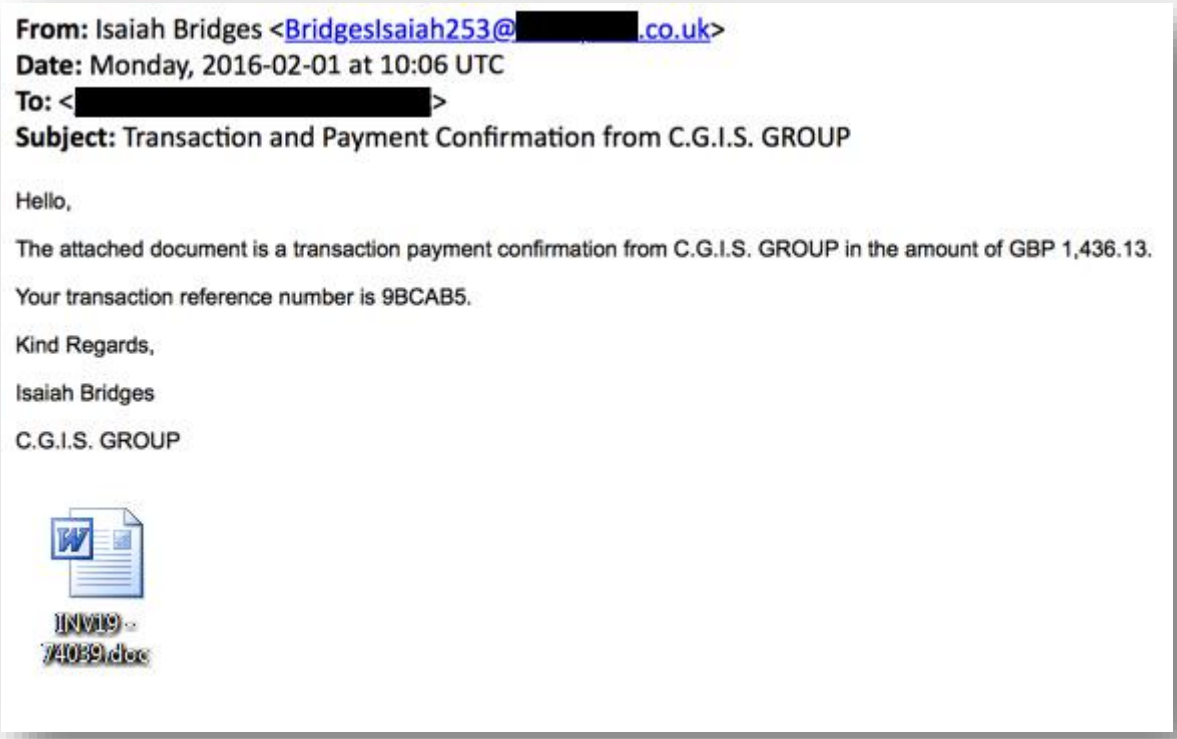
At the moment only the core module (program kernel) named "core" is available. Based on the program functionality, we can conclude that the Trojan targets online banking systems and payment systems. For example, Group-IB analysts detected incidents of scanning infected machines for possible communications with online banking systems of Sberbank, VTB 24 and other payment systems. In particular, the Trojan scans for addresses containing the following substrings: «"bsi.dll?», «online.payment.ru», «/sbi.sberbank», «bankline.ru/servlets/ibc», «faktura.ru», «/iclient/», «ibank2», «bco.vtb24.ru».

The modules that extends the basic program functionality are allegedly designed for both 32-bit systems and 64-bit systems. During its operation the program performs network requests to the livejournal.com website.

Threat name	**Detection**	**Regions attacked**
Dridex	2012	North America, Australia, Africa, Europe, Jamaica

In early 2016 a new version of the Dridex Trojan targeting UK corporate banks was discovered. IBM X-Force specialists note that in the beginning of 2016 this new improved variant was spread through the Andromeda botnet. At the initial phase, Dridex's operators only targeted two banks in the U.K. Later that list expanded to include 13 banks.

Dridex is spread via targeted phishing emails containing MS Office files purporting to be an invoice with poisoned macros. When clicked, these attachments will infect machines to redirect visitors from legitimate bank sites to malicious versions when users try to enter their banking authentication details. Dridex redirects victims via local DNS cache poisoning. Such attacks require creating a realistic replica page of the attacked resource.



From: Isaiah Bridges <BridgesIsaiah253@[redacted].co.uk>
Date: Monday, 2016-02-01 at 10:06 UTC
To: <[redacted]>
Subject: Transaction and Payment Confirmation from C.G.I.S. GROUP

Hello,

The attached document is a transaction payment confirmation from C.G.I.S. GROUP in the amount of GBP 1,436.13.

Your transaction reference number is 9BCAB5.

Kind Regards,

Isaiah Bridges

C.G.I.S. GROUP

INV19 - 74039.doc

Screenshot – An example of malicious email containing Dridex

Targeted emails attacked both the financial sector and industrial and telecommunications companies.

During the first quarter Group-IB specialists detected Dridex using by at least two cybercrime groups:

1) Attacks banks of US, Australia, United Kingdom, France, Spain and also one Pan African bank:

Barclays
Santander
Societegenerale
Bnpparibas
Bancopopular
Ecobank (The Pan African Bank)
Humebank
Danskebank
Ulsterbank
Bankofscotland
Tsb Bank
Lloydsbank
Hsbc
Nationwide
Natwest
Royal Bank of Scotland
Fbnbank
La Banque Postale
Credit-Agricole
Ca-Paris
Caisse-Epargne
Maitland Mutual
Encompass
Halifax

2) Attacks banks of Canada, USA, United Kingdom, Netherlands, but also there are exotic countries among targets: banks of Nigeria and Jamaica:

Bankofamerica
Citibank
Pncbank
Jpmorgan
Tdbank
Bankofthewest
Usbank
Citizensbank
Unionbank
Pacificcapitalbank
Amegybank
Bankofbermuda
BMO Bank of Montreal
Compassbank
Mibank
Colonialbank
Bank 53
Firstbancorp
Lakelandbank
Metrobank
Gtbank (Nigeria)
CIBC
M&T Bank
Sandyspringbank
Nashvillecitizensbank
Firstcitizens
Scotiabank
Frostbank
Fidelitybank
Rabobank
BMOharrisbank
Brannen Bank
Comerica
Firstglobal-Bank (Jamaica)
Centralbankstl
Efirstbank
Firstmerit
Jefferson-Bank
Mandtbank
Mutualofomaha Bank
Synovus
Texascapitalbank
Vancity
Washingtonfederal
Wellsfargo
BNY Mellon
Conexus

Program name	**Detection**	**Attacked regions**
Qadars	2013	USA, Australia, Canada, Italy

Qadars is banking Trojan first publicly discussed in 2013. Its modus operandi is banking fraud through web injection. Qadars uses a wide variety of webinjects, some with Android mobile components, used to bypass online banking security and to gain access to user's bank account. Usually, banking Trojans either target a broad array of financial institutions or focus on a much smaller subset, usually institutions of which the user base is geographically close. Qadars fall in the second category: it pinpoints users in specific regions and uses webinject configuration files tailored to the banks most commonly used by the victims.

During the first quarter, we observed following groups, which use Qadars:

1) For attacks against banks of US and Australia:

ANZ
Banksa
Stgeorge
Westpac
Nab
Commonwealth
Chase
Bankwest

Bankofamerica
Americanexpress
Usbank
Wellsfargo
Bendigobank
Suncorpbank
Adelaidebank
Amp Bank
Bank of Queensland
Bankofmelbourne

2) For attacks against banks of Canada and Italy:

Banque Nationale Du Canada
Scotiabank
Vancouver City Savings Credit Union
First West Credit Union
Toronto Municipal Employees Credit Union
Reddy Kilowatt Credit Union
Provincial Government Employees Credit Union
Tandia Financial Credit Union
Omista Credit Union
Noventis Credit Union
Implicity Financial
Northern Savings Credit Union
The Hamilton Sound Credit Union
Libro Credit Union
Firstcalgary Financial
Memberone Credit Union
Mount Lehman Credit Union
Entegra Credit Union
Prospera Credit Union
G&F Financial Group
Desjardins
Canadian Imperial Bank of Commerce
President's Choice Financial
Tangerine
BMO Bank of Montreal
Poste Italiane
Unicredit
Royal Bank of Canada

Program name	**Detection**	**Attacked regions**
Corebot	2015	North America, Asia-Pacific, Europe

Corebot is banking stealer with Domain Generation Algorithm (DGA) and web-injects, with function of persistence infected system.

Now, we observe cybercrime group, which use Corebot for attacks against banks of USA and Canada, also it attacks Asia-Pacific region: Hong Kong, Singapore, Malaysia, and Indonesia. Besides it, there is Holland bank among targets. The full list of targets:

Mercantile Bank
Bank of Stockton
Bankofamerica
Jpmorgan
Citibank
Wellsfargo
Bank 53
Hsbc
Dbs Bank
Bank of China
Standard Chartered
Maybank
United Overseas Bank
ING

Bank Negara Indonesia
Hang Seng Bank
Canadian Imperial Bank of Commerce
Scotiabank
Tdbank
Americanexpress
Chase

Program name	Detection	Attacked regions
Gootkit	2014	North America, Europe, Brazil

First time Gootkit appeared in summer 2014 and was targeting French banks. Now it has wide geographic distribution zone. Gootkit is a banking trojan that can record video , make screenshots, modify web pages by webinjects, redirect victims to phishing sites, install keylogger, block URLs.

Usually Gootkit is delivered to victims by phishing emails via attached malicious Office documents.

The main feature of Gootkit that makes it different from other baking trojans is that it was fully written on JavaScript. Firstly, loader inspects infected machine and tries to detect virtual environment. If everything is ok, then it downloads JavaScript interpreter V8, sets it to startup and downloads obfuscated JS code. This JavaScript file is the main body of trojan and contains all functionality. In addition, loader can elevate privileges and bypass UAC.

Later number of attacked countries increased. During the first quarter Group-IB specialists observed several cybercrime groups which use Gootkit against different regions:

1) Cybercrime group uses web-injects for attack against 586 financial organizations in France, Italy, Spain, Germany, UK, USA, New Zealand, Belgium, and the Netherlands. Ode of web-inject is available in Bot-Trek Intelligence interface:
https://bt.group-ib.com/#malware/Gootkit/sample/11000452

2) Another group attacks several banks of Canada and USA:
BMO Bank of Montreal
Royal Bank of Canada
Scotiabank
Td Bank

3) Group which attacks mainly Italian banks but also there are France, Brazil and USA among targets:
Crédit Coopératif
Intesa Sanpaolo
Credem Banca
Bper Gruppo
Banca Mediolanum
Banca Popolare Di Milano
Raiffeisen (it)
Chase
Consorzio Servizi Bancari (CSE)
Banca Popolare Pugliese
Inbank

4) Group which attacks banks of the United Kingdom, USA, Canada and one Italian bank:

HSBC
Yorkshire Bank
Clydesdale Bank
Barclays
First Direct
Santander
Citi
Isle Of Man Bank
The Co-Operative Bank
Nationwide
Tescobank
Halifax
TSB
Bankofscotland
Lloydsbank
Royal Bank of Scotland
St. James's Place Bank
Intelligent Finance
Metrobank
Canadian Imperial Bank of Commerce
Banque Nationale Du Canada
Scotiabank
Citi
USAA
Wellsfargo
Americanexpress
Chase
Bankofamerica
Inbank

5) Group which attacks several French banks and Sweden bank:
Swedbank
Crédit Industriel Et Commercial
Lcl Banque
Credit-Agricole
Banquepopulaire
Bnpparibas

Program name	Detection	Attacked regions	Notification
ISFB	2013	Europe, the Asia-Pacific region, Australia	CP-1396

ISFB also known as Gozi2 and Ursnif harvests credentials, primarily targeting online banking websites to perform Automated Clearing House (ACH) and wire fraud. Back in June 2014, we discovered a new malware campaign that was using a new DGA. After unpacking, some of the samples that we retrieved contained an interesting debug string “ISFB” inside the binary code. The malware includes a modular architecture, man-in-the-browser functionality, and a backconnect server that allows threat actors to connect to a bank website through the victim's computer. A new version of the control panel, dubbed “IAP”, is used. The C&C panel was probably rewritten and renamed after a bug affecting the previous version was publicly reported.

During the first quarter facts of source codes of ISFB banking Trojan selling were detected on underground marketplaces. Also Group-IB specialists observed ISFB samples which attack following banks:

Euro Bank SA
BGZ BNP Paribas
Mandiri
Bank Negara Indonesia
Cimbclicks
mBank SA
Citibank

Bank BPH
Bank Zachodni WBK
Aliorbank
Getin Noble Bank
Societe Generale
Credit Agricole
PBS bank
Zwazek Bankow Polskish
Bank BPS
BOS Bank
Volkswagenbank
SGB-Bank SA
Toyotabank
BAWAG P.S.K.
Banca Popolare Di Milano
Raiffeisen Polbank
ING bank
Bank Pekao
ANZ
Commonwealth
NAB
Halifax
Cedacri S.p.A.
Banca Monte Dei Paschi Di Siena
PKO Bank

Mainly there are polish banks in this list and in additional banks of Italy, Austria, United Kingdom, Indonesia and Malaysia, Australia and the attack on Citibank (specific region is not known).

❖ Attacks on POS terminals and ATM

During the reporting period analysts detected activity of GreenDispenser and Suceful Trojans targeting ATM machines in Russia and the Ukraine. They are designed to perform unsanctioned cash withdrawal from ATM machines.

It's worth reminding that Suceful was detected in August 2015; at that moment the program was at the development stage.

Malware name	Detection	Regions attacked
FighterPOS, a new Floki modification	February 2016	All the world

Trend Micro specialists detected two new variants of the FighterPOS Trojan:

1) a FighterPOS lightweight version is only designed to connect to the attacker's server to send payment card logs collected by other malware
2) «Floki Intruder» is capable of spreading itself over the network which the infected device is connected to.

«Floki Intruder» is believed to be a much more dangerous modification of the Floki malware. It is able to enumerate logical drives to drop copies of itself together with an autorun.inf file by using a routine system WMI (Windows Management Instrumentation).

As PoS terminals are usually connected in one network, a propagation function will not only enable the attacker to infect as many terminals as possible, it also makes this threat more difficult to remove because reinfection will occur as long as at least one terminal is affected.

According to analysis results, like FighterPOS, Floki was developed based on the vnLoader botnet client.

Based on the Trend Micro statistics, 93,77% of all detected infections occurred from January 23 to February 16, 2016 targeted Brazil. The rate for the USA increased from 1% (for April 2015) to 6%, which had been allegedly triggered by the Floki appearance.

Malware name	Detection	Regions attacked
CenterPOS 2.0	January 2016	USA

Researchers detected a new CenterPOS malware sample, which contains functionality that allows cybercriminals to create a configuration file to store the C&C information. This function enables the malware operator to easily update the C&C information if necessary.

CenterPOS 2.0 contains two modes for scanning PoS terminals for credit card information. The malware takes any data on the compromised device that matches the criteria list and encrypts it using the TripleDES to further send it to the C&C server after each iteration of scanning. The gathered system data includes all system users, logged in users, sessions, process list, and current settings list.

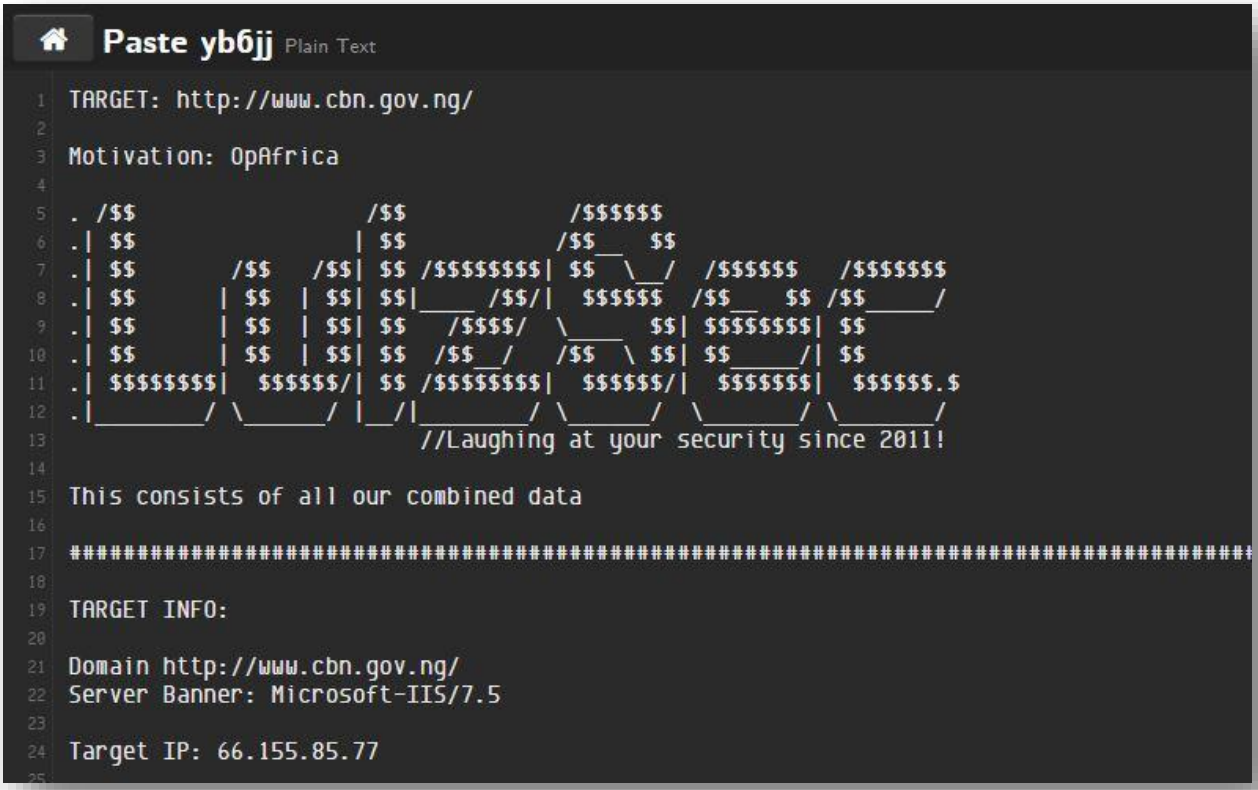
Threats for the Governments

❖ Hacktivism

In Q1 2016, Group-IB detected over 1700 hacktivist attacks on various resources. 935 detected attacks were of "page replacement" type (Deface) and 819 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Italy, Norway, Island, North Korea, Kenya, Tanzania, South Africa, Venezuela, and Belgium. The most active gangs which are believed to have concentrated their attacks on one country were DownSecBelgium (attacks on Belgium government resources), LulzSec Italy (attacks on Italian government resources), OpKCNA (attacks on government and media resources of North Korea), Anti-armenia Team (attacks on Armenian government resources).

Operation name	Regions attacked	Operation start	Types of attacks during the operation
OpAfrica	Eastern Africa, Southern Africa	30.12.2015	DDoS, Deface, Data leakage
	Description: during the operation attacks were conducted against government, financial and non-public organizations of Zimbabwe, South Africa, Niger, Kenya and Ethiopia. In total, we detected 126 incidents, out of them 76 attacks were launched by a hacktivist named Tobitow, a member of the TeamHackArgentino group. Hacktivists of the LulzSec group published data obtained from the Central Bank of Nigeria website (http://www.cbn.gov.ng/) by collecting and analyzing open resource data as well as exploiting SQL injection vulnerabilities on the website.		
OpKenya	Eastern Africa	14.02.2016	DDoS
	Description: during the operations hackers conducted DDoS attacks on government resources of Kenya as part of a larger operation OpAfrica.		
OpISIS	ISIS, Middle East, Islamic organizations all over the world	11.08.2014	DDoS
	Description: during the OpISISoperation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources. In Q1 2016 204 attacks were detected in total with a major part of them organized by BinarySec and New World Hackers hacker groups.		
OpTrump	North America	12.12.2015	DDoS
	Description: during the operation hackers attacked websites related to Donald Trump, an American businessman and politician. Their goal is to "dismantle" Trump's campaign for the US presidential elections.		
OpTurkey	Turkey	10.09.2014	DDoS, Deface
	Description: in Q1 2016 hackers continued attacking Turkish websites. In addition to previously targeted government websites hacktivists started attacking DNS servers related to Turkish internet infrastructure.		
OpVenezuela (OpVzla)	South America	20.01.2011	DDoS, Deface
	Description: in Q1 2016 Venezuelan government websites were attacked including those of Venezuelan President (http://www.presidencia.gob.ve)		

	and Vice President (http://vicepresidencia.gob.ve). Attacks on telecommunications companies included an attack against the CANTV company (http://www.cantv.com.ve).		
OpNiUnaMas	Mexico	18.12.2015	Deface
	Description: during the operation government website of Mexico were attacked. This operation was intended to attract the attention of the Mexican government to to the needs of people.		
OpBEAST, OpWhales, OpKillingBay	North America, North Europe, Southeast Asia		DDoS
	Description: OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Initially they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. At the moment, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, Texas state agencies.		

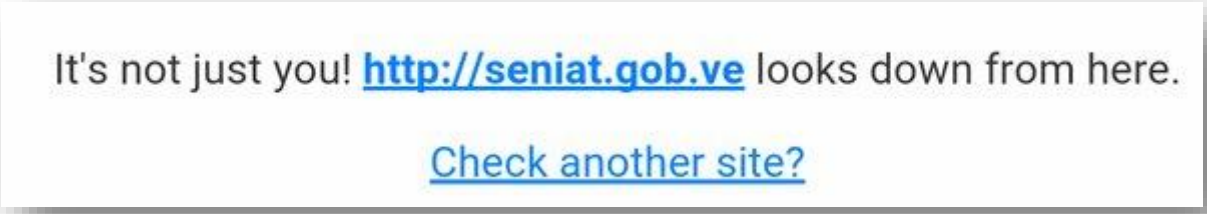


Paste yb6jj Plain Text

```
TARGET: http://www.cbn.gov.ng/

Motivation: OpAfrica

. /$$                  /$$            /$$$$$$
.| $$                | $$           /$$__  $$
.| $$       /$$   /$$| $$ /$$$$$$$$| $$  \__/  /$$$$$$   /$$$$$$$
.| $$      | $$  | $$| $$|____ /$$/|  $$$$$$  /$$__  $$ /$$_____/
.| $$      | $$  | $$| $$   /$$$$/  \____  $$| $$$$$$$$| $$
.| $$      | $$  | $$| $$  /$$__/   /$$  \ $$| $$_____/| $$
.| $$$$$$$$|  $$$$$$/| $$ /$$$$$$$$|  $$$$$$/|  $$$$$$$|  $$$$$$.$
.|_______/ \_____/ |__/|_______/ \_____/  \_____/ \_____/
                          //Laughing at your security since 2011!

This consists of all our combined data

##########################################################################################

TARGET INFO:

Domain http://www.cbn.gov.ng/
Server Banner: Microsoft-IIS/7.5

Target IP: 66.155.85.77
```

Picture - Information from the Central Bank of Nigeria website published for public access

Picture – Message on the OpTrump operation start



Picture – An attack against a Venezuelan government website

Among attacks on government and banking sectors, it is worth pointing out attacks conducted by a hacker named ZoRRo_KiN, a member of the TurkHackTeam gang who is known to have attacked Russian websites in early January.

Date	Description	Domain
06.01.2016	Website of the Ministry of Justice of the Russian Federation	minjust.ru
06.01.2016	Website of the Federal Customs Service of the Russian Federation	customs.ru
06.01.2016	Ministry of Economic Development of the Russian Federation	economy.gov.ru
06.01.2016	Ministry of Energy of the Russian Federation	minenergo.gov.ru
06.01.2016	Website of the Ministry of Defence of the Russian Federation	mil.ru
06.01.2016	Website of the Ministry of Communications and Mass Media of the Russian Federation	minsvyaz.ru

07.01.2016	Website of the Ministry of Labour and Social Protection of the Russian Federation	rosmintrud.ru
07.01.2016	Website of The Russian Government	government.ru
07.01.2016	Website of Prime Minister of the Russian Federation	premier.gov.ru
08.01.2016	Website of ROSATOM, a Russian Federation national nuclear corporation	rosatom.ru
08.01.2016	Common Government Services Portal of the Russian Federation	gosuslugi.ru
08.01.2016	Website of the Ministry of Finance of the Russian Federation	minfin.ru
08.01.2016	Website of the Ministry for Development of the Russian Far East	minvostokrazvitia.ru
08.01.2016	Website of the Ministry of Construction Industry, Housing and Utilities Sector of the Russian Federation	minstroyrf.ru
10.01.2016	Website of Aeroflot, the largest airline of the Russian Federation	aeroflot.ru
12.01.2016	Website of the Ministry of Foreign Affairs of the Russian Federation	mid.ru
12.01.2016	Website of the “Russian Standard” bank	rsb.ru
12.01.2016	Website of Bank of Moscow	bm.ru
12.01.2016	Website of Alfa Bank "	alfabank.ru
13.01.2016	Website of «Alfa-Click», an internet banking system developed by Alfa Bank	click.alfabank.ru
13.01.2016	Website of the “Russian Standard” online banking system	online.rsb.ru
13.01.2016	Website of the VTB Group, a global provider of financial services	vtb.ru

❖ APT - Advanced Persistent Threat

APT name	Regions attacked	Related notifications	Operation start
Buhtrap	Russian Federation	CP-1369 CP-1370 CP-1370-2 Group-IB report “Buhtrap: the evolution of targeted attacks against financial institutions”	September 2014

In January 2016 Group-IB specialists detected a Buhtrap attack where criminals used a new Buhtrap software version with a module enabling them to infect computers in the corporate network. When reacting to the incident we analyzed this module and classified it as a network worm BuhtrapWorm based on its functionality. Group-IB experts acknowledge that it takes much effort to remove BuhtrapWorm from an infected system.

On February 5, 2016 source codes of the previous banking Buhtrap version were published on an underground forum. Based on an archive analysis, this source code version was developed in the period of summer-fall 2015. The author of this publication was a member of the Buhtrap gang.

The BuhtrapWorm appearance and source code publication may trigger an increase in the number of attacks and fraudulent actions using this malware conducted by other groups. Distribution of this new tool designed to infect the corporate network made it more difficult to recover functionality of the local network.

On March 15 a new spear-phishing attack acting as FinCERT, a Russian centre aimed at collecting and sharing cyber-attack information in the Russian banking and financial sector established by the Russian Central Bank, was detected.

APT name	Regions attacked	Related notifications	Operation start
Black Energy	Ukraine, Russia, Poland, Lithuania, Belorussia, Azerbaijan, Kirgizia, Kazakhstan, Iran, Israel	CP-1363	2010

BlackEnergy is a Trojan that is used to conduct industrial cyber espionage. It’s multi-platform modular malware capable of infecting Windows and Linux operating systems. Malware delivery method: phishing emails with a malicious attachment.

We detected attacks targeting companies in several countries, but the most recent attacks (late 2015-early 2016) were detected in the Ukraine. For example, there are evidences of attacks on “Prykarpattyaoblenergo” and “Kyivoblenergo” energy companies and the Boryspil International Airport.

Data Leakage

Group-IB specialists detected new services related to bank inside information – these services are known to have targeted three large Russian banks:

- a service providing access to information on debit cards – account numbers, account opening/closing dates, balance, phone numbers, office visit dates, frequency of replenishment/cash withdrawal;
- a service providing access to confidential information on bank clients. The following information is available for each region:
  - Bank card number
  - Account number
  - Balance
  - Code word
  - Phone number liked to the account
  - Client's passport data
- a service providing information on bank clients: all information on an account or a card, cash flow statement.

Major data leaks covered in media:

- In early February US-based retailer Neiman Marcus Group confirmed a massive data breach related to online customer accounts. Criminals managed to gain access to personal and financial information including names, home and email addresses, phone numbers, the last four digits of a payment card and sales history. Social insurance numbers, birth dates and similar bank data were not exposed. Approximately 70 accounts were used by criminals to conduct unsanctioned purchases;
- Criminals stole customers' bank card data of such companies as Wendy's (a fast food restaurant chain) and Uber (a taxi service);
- Nexus Mods, a site aimed to develop mods for online games, was reported to have suffered a database breach. The leaked database contained details of 6 million users.
- The American Express payment system notified its users that their data may have been compromised in a third-party breach. Purportedly, a partner merchant experienced unauthorized access to its IT system. American Express did not inform how many records were accessed, nor did it identify the third party. The exposed data can be potentially used in fraudulent operations or sold on the black market.